PRIVILEGED ACCESS MANAGEMENT PROCESS

SOP-009 | Standard Operating Procedure | Issued under POL-009

Document ID: SOP-009
Version: 1.0 — DRAFT
Parent Policy: POL-009 — Privileged Access Management Policy
Classification: Confidential
Owner: Information Security
Co-Owner: Data Custodian (IT)
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Privileged Access Management Process
Document ID	SOP-009
Version	1.0 — DRAFT
Document Classification	Confidential — access to this SOP is restricted to Information Security, Data Custodian (IT), CISO, Compliance / QA, and named System Owners. The break-glass procedure (Section 6) must not be distributed beyond the authorised CISO and Deputy CISO.
Parent Policy	POL-009 — Privileged Access Management Policy
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-008 (Access Control), POL-010 (IS Risk), POL-012 (Incident Response), POL-014 (Audit Trail), SOP-007 (Change Management Process), SOP-008 (Access Control Process), SOP-012 (Incident Response Process), EXC-001 (Exception Management)
Owner	Information Security Manager
Co-Owner	Data Custodian (IT)
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

IMPORTANT: This SOP is classified CONFIDENTIAL. The break-glass account envelope locations and credential vault access details referenced in Sections 5 and 6 are held separately and are not included in this document. Section 6 (Break-Glass Process) describes the procedure; the physical envelope location is communicated to authorised individuals separately by the CISO.

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose

This SOP defines the operational workflow for requesting, approving, issuing, monitoring, and revoking privileged access across [Company Name] systems. It operationalises POL-009 by establishing specific procedures for the four privileged access types: human administrator accounts, service and system accounts, third-party privileged access, and break-glass emergency accounts.

Privileged access is the highest-risk category of access in any IT environment. A privileged user can alter system configurations, access all data, modify or suppress audit trail records, and — on GxP systems — take actions that affect the validated state without leaving a routine operational footprint. The controls in this SOP are calibrated to that risk level: they are more stringent than standard access controls (SOP-008) in every dimension.

> **NOTE:** The core design principle of this SOP is no standing privileged access to Tier 1 and GxP production systems. Privileged access to these systems is issued just-in-time for a specific activity, session-recorded, and revoked when the activity is complete. There is no exception to this principle for convenience — that is the point.

2. Scope

This SOP applies to all privileged access accounts at [Company Name]:

- Human administrator accounts: system administrators, database administrators, network administrators, security administrators, and any account with elevated rights on a production system
- Service and system accounts: non-human accounts used for application-to-application communication, scheduled jobs, integration services, and automated processes
- Third-party privileged accounts: vendor, consultant, or contractor accounts with elevated access to [Company Name] production systems
- Break-glass emergency accounts: pre-provisioned emergency access accounts used when normal privileged access mechanisms are unavailable

Standard user accounts are governed by SOP-008. Where a user holds both standard and privileged access (e.g., a system administrator who also has a standard user account for day-to-day work), the privileged account is governed by this SOP and the standard account by SOP-008 — the two accounts are separate and must not be used interchangeably.

3. PAM Platform and Vault

All privileged credentials for Tier 1, Tier 2, GxP, and SOX systems are stored in the [Company Name] PAM vault — the approved Privileged Access Management platform. The PAM vault is itself a Tier 1 system and subject to the highest controls in the IMF suite.

PAM Capability	Requirement	Applicable Tiers
Credential vault	All privileged credentials stored in PAM vault — not in spreadsheets, shared drives, email, or personal password managers	Tier 1, Tier 2, GxP, SOX — mandatory. Tier 3/4 — strongly recommended.
Credential rotation	Automatic rotation per schedule. Manual rotation on: each privileged session end (JIT model), account compromise suspicion, personnel change, break-glass use, and at maximum rotation interval.	Tier 1/GxP: 90-day maximum rotation interval, immediate rotation after each use for JIT accounts. Tier 2: 90-day maximum. Tier 3/4: annual minimum.
Session recording	All privileged sessions recorded: keystrokes, screen activity, commands executed, timestamps	Tier 1 and GxP/SOX: mandatory. Tier 2: mandatory for database and OS administrator sessions. Tier 3/4: recommended.
JIT access issuance	Access issued on demand for a defined session window, revoked automatically at session end	Tier 1 and GxP: mandatory. Tier 2: required for database and cloud infrastructure. Tier 3/4: not required.
Dual approval for sensitive operations	Some operations require a second approver to authorise the session before credentials are released	Audit trail configuration changes on Tier 1/GxP: mandatory. GxP validated configuration changes: mandatory.
Session termination	PAM platform automatically revokes JIT access at session timeout — implementer cannot extend without a new access request	Tier 1 and GxP: mandatory automatic revocation

PAM vault access is itself privileged access — PAM administrators are subject to this SOP. The PAM administrator account list is reviewed monthly by the CISO. No individual may self-provision access to the PAM vault.

4. Privileged Access Request and Approval

Step 01	**Privileged Access Request Submission** All privileged access requests are submitted via the ITSM platform as	Responsible **Requester / System Owner**

	Normal change requests under SOP-007 (privileged access provisioning is never a Standard change). Mandatory request fields — in addition to standard SOP-007 Normal change fields: — Privileged account type: human admin / service account / third-party privileged / time-limited elevated — Specific privileges requested: exact role, group memberships, or permissions — not 'admin access' — Target system(s) and their tier and regulatory flags — Business justification with named activity or project — Access duration: permanent standing access (Tier 2/3/4 only) or JIT per session (Tier 1/GxP mandatory) — For GxP systems: Validation Impact Assessment confirming the privileged access does not alter the validated configuration beyond the intended scope — For service accounts: owning application, owning team, purpose, systems accessed, and whether interactive login is required (it should not be) Requests for 'broad admin access' or 'full system administrator rights' on Tier 1 or GxP systems are returned to the requester with a requirement to scope the request to the minimum privileges necessary for the specific activity.	
Step 02	**Privileged Access Review and Approval** Approval authority for privileged access requests: Tier 3/4 systems: — Information Security Manager approval Tier 2 systems: — Information Security Manager approval — System Owner approval Tier 1 systems: — CISO approval — System Owner approval — Information Security Manager review GxP systems (in addition to tier-based approval): — Compliance / QA Director confirmation that the privileged access does not require additional validation activities before being granted Audit trail configuration changes on any tier: — CISO approval — DIO co-approval All approvals recorded in ITSM with approver identity and timestamp. The PAM vault entry is not created until all required approvals are confirmed.	Responsible **CISO / Information Security Manager / System Owner / Compliance QA**
Step 03	**PAM Vault Entry and JIT Configuration** On final approval, Data Custodian (IT) creates the PAM vault entry: For JIT accounts (Tier 1/GxP mandatory): — Credential created in PAM vault but not released to the requester — JIT session parameters configured: maximum session duration, session recording enabled, auto-revocation on timeout — Dual approval requirement configured if applicable (audit trail config changes) — Access request workflow created in PAM platform: requester submits session request, approver releases credentials for the specific session For standing access (Tier 2/3/4 only): — Credential created in PAM vault — Access provisioned in target system — Session recording configured where required — Rotation schedule configured Privileged Account Inventory updated: account ID, type, owner, system, tier, GxP flag, rotation schedule, next review date, PAM vault reference.	Responsible **Data Custodian (IT)**

5. JIT Access Session Process (Tier 1 and GxP Systems)

Every privileged session on a Tier 1 or GxP system follows this workflow. Standing privileged access to these systems is not permitted — each session is a separately authorised event.

Step 01	**Session Request** The privileged user submits a session request in the PAM platform: — Target system and specific privileged function required — Activity to be performed (specific — not 'maintenance') — Associated change record reference (SOP-007 change request) if the session involves a change activity — Estimated session duration For GxP systems: the session must be associated with an approved change record (SOP-007) or an approved incident record (SOP-015). Ad-hoc privileged sessions on GxP production systems without an associated record are not permitted.	Responsible **Privileged User**
Step 02	**Session Approval and Credential Release** The PAM platform routes the session request to the designated approver: Standard session (change or maintenance activity): — Information Security Manager or designated delegate approves — Approval includes confirmation that an associated change record exists and is approved Audit trail configuration session or GxP validated configuration session: — Dual approval required: CISO + DIO (audit trail config) or CISO + Compliance/QA Director (GxP configuration) — Both approvers must approve in the PAM platform before credentials are released On approval: PAM vault releases a time-limited credential valid for the approved session duration only. The credential is not visible to the privileged user in cleartext — it is injected directly into the session by the PAM client.	Responsible **Information Security Manager / CISO (dual approval sessions)**
Step 03	**Session Execution** The privileged session is conducted through the PAM client, which: — Records the complete session: all keystrokes, commands, screen activity, and timestamps — Displays the session timer — privileged user is aware of remaining session time — Sends a warning alert 15 minutes before session expiry — Automatically revokes credentials and terminates the connection at session expiry During the session: — The privileged user performs only the activity stated in the session request — Any deviation from the stated activity must be declared to the Information Security Manager immediately — For GxP systems: the system audit trail confirms all actions taken — the PAM session recording and the system audit trail together constitute the complete privileged activity record If the session expires before the activity is complete: a new session request is submitted. The incomplete activity is documented in the new request. The incomplete session is not grounds for extending the original session outside the PAM workflow.	Responsible **Privileged User**
Step 04	**Post-Session Review** All Tier 1 and GxP privileged sessions are subject to post-session review: Automated review (all sessions): — PAM platform generates a session summary: commands executed, duration, files accessed, network	Responsible **Information Security / Information Security**

	connections made — Anomaly detection: commands or activity outside the stated session purpose flagged for manual review — Session recording archived in PAM vault (retention per POL-014 — minimum 3 years for security sessions, GxP retention period for GxP sessions) Manual review (sampled or triggered): — Information Security Manager reviews a 10% random sample of Tier 1/GxP sessions monthly — All sessions flagged by anomaly detection are reviewed within 2 business days — Sessions associated with Emergency Changes are reviewed within 24 hours — Any session where the activity appears to exceed the stated scope: escalated to CISO immediately	**Manager**

6. Break-Glass Emergency Access Procedure

Break-glass accounts are pre-provisioned emergency access accounts used when the normal PAM workflow is unavailable — for example, during a major PAM platform outage, a system lockout, or a scenario where the standard JIT approval chain cannot be completed in time to prevent critical service impact.

IMPORTANT: Break-glass access is the highest-risk privileged access event in [Company Name]'s operating environment. It bypasses the standard PAM workflow and uses pre-created credentials stored outside the PAM vault. Every use of break-glass access must be treated as a potential security incident until confirmed otherwise — not because the user is assumed to be malicious, but because the circumstances that require break-glass access (system outage, credential lockout) are also consistent with the early stages of some attack patterns.

6.1 Break-Glass Account Provisioning

Break-glass accounts are provisioned and maintained by the CISO:

- One break-glass account per Tier 1 system and per GxP system — named 'BREAKGLASS-[SYSTEM]-001' format
- Credentials stored in physically sealed envelopes in the [Company Name] secure physical vault — location known only to CISO and Deputy CISO
- A second sealed envelope held at [secondary secure location — defined separately by CISO] for geographic redundancy
- Envelope seal integrity reviewed quarterly by CISO — any broken seal treated as a potential access event
- Credentials rotated: after every use; at every quarterly review regardless of use; on CISO personnel change; annually at minimum
- Break-glass account access does not include network access by default — network access is activated separately on a per-incident basis by Data Custodian (IT) on CISO instruction

6.2 Break-Glass Activation and Use

Step 01	**Break-Glass Authorisation** Before any break-glass envelope is opened: 1. The individual requiring access contacts the CISO directly (phone — not email, not ITSM) 2. CISO assesses the situation and confirms that normal PAM access is genuinely unavailable and the activity cannot wait for normal access to be restored 3. CISO provides verbal authorisation — naming the specific system, the specific individual, and the specific activity authorised 4. CISO records: time of authorisation, authorised individual, system, activity, reason PAM was unavailable 5. If CISO is unreachable: Deputy CISO provides authorisation using the same process. If both are unreachable: CIO provides authorisation and CISO is notified as soon as available Break-glass access is never self-authorised. An individual cannot authorise their own break-glass access under any circumstances.	Responsible **CISO / Deputy CISO / CIO**
Step 02	**Envelope Opening and Access** Envelope opening requires a witness: 1. The authorised individual and a witness (named Information Security team member or, if unavailable, a senior manager) retrieve the sealed envelope from the vault 2. Both individuals confirm: envelope seal is intact before opening; if seal is broken, this is treated as a security incident and CISO is notified before proceeding 3. Envelope is opened in the presence of the witness 4. Credential used to access the target system 5. Witness documents: time of envelope opening, seal status, individuals present, system accessed Throughout the break-glass session: the witness remains present. All actions are documented in real time — timestamps, commands executed, systems accessed, changes made.	Responsible **Authorised Individual / Witness**
Step 03	**Immediate Post-Use Actions** On completion of the break-glass activity: 1. Credential immediately invalidated: Data Custodian (IT) resets the break-glass account password immediately after the session ends — not deferred 2. New credential generated and placed in a new sealed envelope — sealed immediately 3. Used envelope and old credentials destroyed securely (shredder) 4. New envelope returned to the vault — CISO confirms vault receipt 5. System audit trail reviewed: confirm all actions during the break-glass session are recorded in the system audit trail; if any gap detected → immediate SOP-012 security incident raised 6. CISO notified of completion: time of completion, activity performed, any anomalies	Responsible **Data Custodian (IT) / CISO**
Step 04	**48-Hour Post-Use Review** Within 48 hours of break-glass use: 1. Formal Break-Glass Use Report produced by Information Security: authorisation details, activity performed, systems accessed, all changes made, audit trail review outcome 2. The report is reviewed and signed by CISO 3. For GxP systems: Compliance / QA Director reviews the Break-Glass Use Report; assesses whether the activity during the break-glass session requires VMF documentation or a deviation record; issues a validated state	Responsible **Information Security / CISO / Compliance QA (GxP)**

assessment 4. All break-glass use events are reported to the ISSG at the next meeting — or immediately if the break-glass use indicates a systemic vulnerability 5. Break-Glass Use Report filed: in the ITSM system as an incident record; in the VMF for GxP systems; retained per POL-002 (security incidents: 7 years for P1, per retention schedule otherwise)

7. Service Account Management

Service accounts are non-human accounts used by applications, scheduled jobs, and integration services. They are privileged accounts by definition because they operate autonomously, often with elevated permissions, and are not subject to the human oversight that applies to interactive sessions. Unmanaged service accounts are a persistent attack surface — they are commonly used in lateral movement and privilege escalation.

Control	Requirement	Rationale
One purpose per account	Each service account is created for a single application or process — not shared across multiple applications	Compromised shared service accounts expose multiple applications. Single-purpose accounts limit blast radius.
Named owner	Every service account has a named human owner responsible for it — the owner of the application that uses the account	Unowned accounts are never reviewed and are rarely deprovisioned.
No interactive login	Service accounts are configured to prevent interactive (human) login in the target system where technically feasible	Interactive login on a service account is an anomaly and a security alert — it means a human is using a non-human account, bypassing audit attribution.
Credentials in PAM vault	Service account credentials stored in the PAM vault — not hardcoded in application configuration files, scripts, or environment variables	Hardcoded credentials in configuration files are routinely exposed in code repositories and are not rotatable without code changes.
Rotation schedule	Tier 1/GxP: 90-day maximum rotation. Tier 2: 90 days. Tier 3/4: annual minimum. Immediate rotation on any compromise suspicion.	Stale credentials are a persistent risk. Rotation limits the window of exposure if a credential is compromised without detection.
Least privilege	Service account permissions scoped to the specific operations the application needs — not broad database owner or system administrator	Over-privileged service accounts are the primary mechanism through which application vulnerabilities are escalated to system compromise.

Control	Requirement	Rationale
	rights	
Inventory and quarterly reconciliation	All service accounts are in the Privileged Account Inventory. Quarterly reconciliation confirms no undiscovered accounts exist (discovery scan per quarter).	Shadow service accounts created during application deployments and forgotten are a persistent risk.

7.1 Service Account Creation

Service account creation follows the Normal change process under SOP-007. The creation request includes: account name and naming convention compliance (SVC-[APPNAME]-[PURPOSE]); owning application; owning team; target systems and required permissions; whether interactive login can be technically prohibited; and credential storage approach (PAM vault reference).

Service accounts on GxP systems require Compliance / QA confirmation that the account's automated actions are within the validated configuration scope and that the account's activity will be recorded in the system audit trail with sufficient attribution to distinguish service account activity from user activity.

7.2 Service Account Decommissioning

When an application using a service account is decommissioned, the service account is decommissioned at the same time — not after, not later. The decommissioning process mirrors the leaver process in SOP-008: account disabled immediately on application decommission, removed from all target systems within 5 business days, deleted after 30-day retention window. The Privileged Account Inventory is updated and a quarterly reconciliation verifies no orphaned service accounts remain.

8. Privileged Access Review

Account Type	Review Frequency	Reviewer	Review Scope
Tier 1 / GxP human admin accounts	Monthly	CISO + Information Security Manager	All active privileged accounts. JIT access usage reviewed (sessions in last 30 days, activity confirmed appropriate). Any standing access on Tier 1/GxP systems flagged as exception requiring EXC-001 approval. Dormant privileged accounts (no use in

Account Type	Review Frequency	Reviewer	Review Scope
			30 days) — access suspended pending Line Manager justification.
SOX ITGC privileged accounts	Monthly	Information Security Manager + Finance Controller	All active privileged accounts on SOX systems. Privilege scope confirmed against minimum necessary for ITGC role. SoD confirmed.
Tier 2 privileged accounts	Quarterly	Information Security Manager + System Owner	All active privileged accounts. Privilege scope appropriate. No unnecessary standing access.
Service accounts (all tiers)	Quarterly — discovery scan + manual review	Information Security Manager + Data Custodian (IT)	Privileged Account Inventory reconciled against discovery scan. Undiscovered accounts are security incidents. Ownership confirmed for all accounts. Rotation compliance confirmed.
Break-glass accounts	Quarterly — envelope seal integrity only. Full review on use.	CISO	Envelope seal intact. Account exists in target system. Credential not used since last rotation (confirmed via system audit trail). Network access component remains disabled.
Third-party privileged accounts	Monthly (Tier A vendors) / Quarterly (Tier B)	Information Security Manager + System Owner	Active third-party privileged accounts confirmed against current engagement scope. JIT session records reviewed. Any third-party account active outside a confirmed engagement window — suspended immediately.

9. Related Documents

Document ID	Title	Relationship
POL-009	Privileged Access Management Policy	Parent policy — this SOP operationalises POL-009
POL-005	System Classification Policy	System tier and GxP flag determine JIT requirement, session recording, approval authority, and review frequency for privileged access
POL-006	Computer System Validation Policy	Privileged access to GxP systems is a validated configuration element; privileged configuration changes require VIA per SOP-006; break-glass use on GxP system requires validated state

Document ID	Title	Relationship
		assessment
POL-007	Change Management Policy	Privileged access provisioning is a Normal change under SOP-007; JIT sessions for change activities are linked to the SOP-007 change record; Emergency Changes use break-glass process only when PAM is unavailable
POL-008	Access Control Policy	Standard access governed by SOP-008; this SOP governs privileged elements; no individual's privileged account may be used for standard work tasks
POL-010	Information Security Risk Policy	Undiscovered service accounts, unrotated credentials, and patterns of anomalous privileged access are IS risks escalated to the Risk Register
POL-012	Incident Response Policy	Compromised privileged accounts are P1 security incidents; break-glass use with unconfirmed seal integrity is a P2 incident minimum; anomalous privileged session activity triggers SOP-012
POL-014	Audit Trail and Monitoring Policy	Audit trail configuration access requires dual CISO + DIO approval; privileged session recordings are retained per POL-014 retention schedule; PAM session records complement system audit trail
SOP-007	Change Management Process	Privileged access requests are Normal changes; JIT sessions for change activities require associated SOP-007 change record
SOP-008	Access Control Process	Companion SOP for standard access — joiner/mover/leaver lifecycle for standard accounts; SOP-009 applies to privileged elements of those lifecycle events
SOP-012	Security Incident Response Process	Compromised privileged credentials, anomalous privileged sessions, and unconfirmed break-glass envelope seal are security incidents under SOP-012
EXC-001	Exception Management Policy and Register	Standing privileged access to Tier 1/GxP systems (deviation from JIT requirement) requires EXC-001 exception with 3-month maximum; exception requires CISO approval and enhanced monitoring as compensating control
RACI-001	Roles, Responsibilities and Authorities	Accountability for privileged access management governance

10. Definitions

Term	Definition
Break-Glass Account	A pre-provisioned emergency access account used when normal PAM access mechanisms are unavailable. Credentials stored in a physically sealed envelope in a secure vault. Use requires CISO verbal authorisation and witness presence.
JIT Access	Just-in-time access — privileged access issued on demand for a specific session, with credentials that are valid only for the approved session duration and revoked automatically at session end.
PAM Platform	The Privileged Access Management platform used to vault credentials, issue JIT access, enforce session recording, and manage privileged account lifecycle.
PAM Vault	The credential store within the PAM platform. All privileged credentials for Tier 1, Tier 2, GxP, and SOX systems are stored here, not in configuration files or personal password managers.
Privileged Account	Any account with elevated permissions beyond those of a standard user — including system administrator, database administrator, network administrator, service account, and break-glass account.
Privileged Account Inventory	The authoritative register of all privileged accounts across [Company Name] systems — maintained by Data Custodian (IT), reviewed monthly by CISO for Tier 1/GxP accounts.
Service Account	A non-human account used by an application, scheduled job, or integration service to perform automated operations. Named SVC-[APPNAME]-[PURPOSE].
Session Recording	The PAM platform capability that records all activity in a privileged session — keystrokes, commands, screen activity — creating an immutable audit record of what was done during the session.
Standing Access	Persistent privileged access that remains active between sessions without JIT activation. Prohibited for Tier 1 and GxP systems. Permitted for Tier 2/3/4 with PAM vault management.

— End of Document —

SOP-009 v1.0 DRAFT | [Company Name] | CONFIDENTIAL